Operación Trazabilidad · Libreta de auditoría

Actividad educativa sobre el caso ficticio RedNova

> **Alcance:** conclusiones estructuradas sobre resúmenes del caso ficticio RedNova. No sustituye el informe del curso, la revisión humana, la base SQL ni los hallazgos académicos.

«Documentado» significa que se reunieron las fuentes y respuestas estructuradas exigidas para esta actividad educativa. Puede conservar una conclusión no concluyente; no aprueba hallazgos académicos, causalidad ni autoría.

RedNova es una empresa ficticia de internet y televisión. El caso reporta la caída de su sistema comercial y archivos aparentemente cifrados. Investiga qué puede sostenerse y qué falta comprobar: no hay registros originales de la empresa.

Distingue cinco clases de información: datos reportados por el caso; declaraciones que deben contrastarse; resultados ficticios del laboratorio; hipótesis por investigar; y datos desconocidos. La oficina y sus animaciones son ilustrativas.

Tres explicaciones abiertas

Ninguna está demostrada. Para distinguirlas:

- **Posible robo de credenciales**

  Una persona no autorizada pudo obtener la contraseña. La sesión sin verificación adicional es compatible con ello, pero no conecta las demás acciones.

  Buscar registros originales que conecten sesión, equipo, proceso y archivos enviados. Una transferencia autorizada o procesos independientes debilitarían esa cadena.

- **Posible uso indebido de un acceso legítimo**

  Alguien que tenía acceso pudo exceder sus autorizaciones. El nombre de la cuenta no identifica a la persona ni su intención.

  Obtener asignación histórica de la cuenta, dispositivo, autorizaciones y acciones. Un robo de credenciales documentado ajeno al titular debilitaría esa atribución.

- **Posible actividad autorizada coincidente con un ataque por otra vía**

  La lectura, el envío o la instalación pudieron tener una finalidad legítima. La aprobación verbal y un destino sin clasificar no acreditan autorización.

  Obtener tarea programada, archivos, destino, aprobación y evidencia de la otra vía de ataque. Contenido no autorizado conectado técnicamente al ataque refutaría la legitimidad de esa actividad.

Observaciones pendientes de comprobar

Ambas observaciones son no concluyentes; las buenas prácticas externas no se acreditaron como obligación de la empresa.

- **Seguimiento de la alerta pendiente de comprobar**

  Faltan asignación, primera acción, escalamiento y cierre documentados. Un registro íntegro podría retirar o reformular esta observación. No se ha probado inacción.

- **Protección de los registros pendiente de comprobar**

  Faltan permisos históricos, reglas de conservación y copias independientes. Una copia protegida con permisos verificados podría acotar la observación. No se ha probado manipulación.

Comparación de tamaños · cálculo de laboratorio

Cálculo de laboratorio: siete campos de 31,840 clientes ficticios ocupan 2,058,909 bytes en CSV (tabla de texto), unos 2.06 megabytes; o 5,115,483 bytes en JSON Lines (nombres de campo repetidos), unos 5.12 megabytes. Es mucho menos que los aproximadamente 1.6 GB reportados. No reconstruye el envío ni confirma o descarta una extracción sin autorización: faltan contenido, destino, proceso y autorización. Los cuatro minutos entre lectura y transferencia no indican la duración del envío.

Acceso remoto y autorizaciones Documentado

Referencia de revisión: AU-01

MFA (autenticación multifactor) exige factores distintos, como contraseña y código de una aplicación. VPN es una conexión privada a la red; API es una interfaz entre programas. Recertificar es revisar con el responsable qué cuentas y permisos siguen justificados.

La sesión de ext_ops_04 no identifica a una persona ni enlaza por sí sola la elevación o la lectura SQL. La política y sus excepciones siguen pendientes.

Conclusión estructurada

Se reporta una sesión sin verificación adicional a la contraseña (MFA) y cuentas sin revisión de permisos reciente; faltan política aplicable, autorizaciones, identidad personal y conexión con las demás acciones.

Referencia: A01-OBSERVACION

Fuentes vinculadas

- Usuarios y permisos (E-01) · versión auditoria_oficina_v2.1
- Acceso remoto (E-02) · versión auditoria_oficina_v2.1

Comprobaciones

- **Pregunta:** ¿Estos datos identifican a la persona que entró y bastan para declarar un incumplimiento de política?

  Respuesta elegida: No; faltan atribución personal y criterio aplicable.

  Referencias: C01-ALCANCE · FALTAN_IDENTIDAD_Y_CRITERIO

  Fuentes: Usuarios y permisos (E-01) · versión auditoria_oficina_v2.1; Acceso remoto (E-02) · versión auditoria_oficina_v2.1

Limitaciones

- La cuenta no equivale a la persona que la utilizó. (L01-ATRIBUCION)
- No se aportó política aplicable ni su alcance. (L01-CRITERIO)

Solicitudes y pendientes

- Solicitar política de acceso y alcance aprobado. (S01-POLITICA)

Acciones propuestas relacionadas

- Acción 1: Organizar la respuesta y registrar decisiones. Propuesta; no ejecutada.
- Acción 4: Decidir aislamiento selectivo y revocar accesos en riesgo. Propuesta; no ejecutada.
- Acción 5: Obtener permisos, conservación y configuración de relojes. Propuesta; no ejecutada.

Anotación personal · sin evaluación automática

Sin anotación personal.

Recomendación y prueba de cierre · sin evaluación automática

Acción: No registrada
Responsable: No asignado
Plazo propuesto: No registrado
Verificación: No registrada

Lectura y transferencia Documentado

Referencia de revisión: AU-02

SQL es el lenguaje de consulta de datos; SELECT permite leerlos. Exfiltración significa salida no autorizada de información: el volumen de tráfico no identifica el contenido ni su autorización.

El caso reporta una lectura de 31,840 registros y aproximadamente 1.6 GB de tráfico. No se demuestra que esos registros fueran enviados ni que la salida careciera de autorización. El editor consulta resúmenes locales; las consultas de los anexos se probaron con datos ficticios y no corroboran el incidente.

Conclusión estructurada

Se reportan lectura de 31,840 registros y transferencia de ~1.6 GB; contenido y vínculo no identificados.

Referencia: A02-TRANSFERENCIA

Fuentes vinculadas

- Lectura masiva de clientes (E-03) · versión auditoria_oficina_v2.1
- Transferencia externa (E-04) · versión auditoria_oficina_v2.1
- Declaración de Seguridad Informática (DECL-05) · versión auditoria_oficina_v2.1

Comprobaciones

- **Pregunta:** ¿Estos registros identifican el contenido transferido y lo conectan con la lectura SQL?

  Respuesta elegida: No; falta correlación entre los eventos y el contenido.

  Referencias: C02-CONTENIDO · SIN_VINCULO_NI_CONTENIDO

  Fuentes: Lectura masiva de clientes (E-03) · versión auditoria_oficina_v2.1; Transferencia externa (E-04) · versión auditoria_oficina_v2.1; Declaración de Seguridad Informática (DECL-05) · versión auditoria_oficina_v2.1

Limitaciones

- El contenido transferido está sin identificar. (L02-CONTENIDO)
- No se demuestra que lo leído sea lo transferido. (L02-VINCULO)
- La sesión conocida no atribuye todas las operaciones a la misma persona o cuenta. (L02-ATRIBUCION)

Solicitudes y pendientes

- Solicitar registros de flujo, destino y proceso de origen correlacionables. (S02-FLUJO)

Acciones propuestas relacionadas

- Acción 3: Preservar registros, memoria e imágenes de equipos disponibles. Propuesta; no ejecutada.
- Acción 6: Investigar contenido y autorización de la transferencia externa. Propuesta; no ejecutada.

Anotación personal · sin evaluación automática

Sin anotación personal.

Recomendación y prueba de cierre · sin evaluación automática

Acción: Conservar y correlacionar los registros disponibles.
Responsable: Seguridad
Plazo propuesto: 24 h desde la activación futura del plan
Verificación: No registrada

Órdenes e instalación de software Documentado

Referencia de revisión: AU-03

CRM es el sistema de gestión de clientes y órdenes. Conciliar significa comparar historial de órdenes y facturación para identificar y explicar diferencias. BD significa base de datos.

El caso reporta 216 órdenes. Los 144 cambios de monto y 72 de estado son supuestos del laboratorio, sin cuenta, sesión ni vía conocidas. Los diez pares candidatos a duplicidad son otras veinte órdenes ficticias y no prueban doble cobro. Falta comparar las órdenes con facturas, pagos, autorizaciones y un respaldo validado.

Conclusión estructurada

Los cambios reportados preceden al instalación de software; integridad, aprobación formal, autoría y relación causal siguen sin demostrarse.

Referencia: A03-PENDIENTES

Fuentes vinculadas

- Modificación de órdenes (EVT-06) · versión auditoria_oficina_v2.1
- Instalación de una nueva versión de integración (EVT-07) · versión auditoria_oficina_v2.1
- Autorización de instalación de software (E-06) · versión auditoria_oficina_v2.1
- Declaración de Desarrollo (DECL-03) · versión auditoria_oficina_v2.1
- Declaración de Administrador de base de datos (DECL-04) · versión auditoria_oficina_v2.1

Comprobaciones

- **Pregunta:** ¿Qué orden muestran las horas reportadas de cambios y instalación de software?

  Respuesta elegida: Los cambios ocurrieron antes del instalación de software.

  Referencias: C03-ORDEN · ORDENES_ANTES

  Fuentes: Modificación de órdenes (EVT-06) · versión auditoria_oficina_v2.1; Instalación de una nueva versión de integración (EVT-07) · versión auditoria_oficina_v2.1

- **Pregunta:** ¿Las declaraciones bastan para dar por verificadas la integridad y la aprobación formal?

  Respuesta elegida: No; faltan comparación de órdenes y facturas concluida y aprobación formal.

  Referencias: C03-SOPORTES · FALTAN_CONCILIACION_Y_APROBACION

  Fuentes: Modificación de órdenes (EVT-06) · versión auditoria_oficina_v2.1; Autorización de instalación de software (E-06) · versión auditoria_oficina_v2.1; Declaración de Desarrollo (DECL-03) · versión auditoria_oficina_v2.1; Declaración de Administrador de base de datos (DECL-04) · versión auditoria_oficina_v2.1

Limitaciones

- El orden de las horas no demuestra que el instalación de software causara el incidente ni que fuera ajeno a él. (L03-CAUSA)
- La comparación de órdenes y facturas no ha concluido. (L03-INTEGRIDAD)
- Los cambios no tienen atribución probada. (L03-ATRIBUCION)
- La falta de aprobación documentada no prueba que jamás se autorizó. (L03-APROBACION)

Solicitudes y pendientes

- Solicitar historial y comparación de órdenes y facturas reproducible de órdenes y facturación. (S03-CONCILIACION)

Acciones propuestas relacionadas

- Acción 7: Restaurar un respaldo validado en un entorno separado. Propuesta; no ejecutada.
- Acción 8: Comparar órdenes afectadas con historial, facturación y respaldo. Propuesta; no ejecutada.
- Acción 11: Decidir retorno progresivo del servicio con aceptación del negocio. Propuesta; no ejecutada.

Anotación personal · sin evaluación automática

Sin anotación personal.

Recomendación y prueba de cierre · sin evaluación automática

Acción: No registrada
Responsable: No asignado
Plazo propuesto: No registrado
Verificación: No registrada

Alerta y atención Documentado

Referencia de revisión: AU-04

SIEM es el sistema que reúne registros y genera alertas de seguridad. La alerta reportada de las 03:18 no incluye asignación, primera acción ni cierre documentados.

Seguimiento de la alerta pendiente de comprobar. Los 61 minutos entre sesión y alerta y los 24 hasta la caída son diferencias de horas reportadas. No prueban tiempo de detección, inacción ni pérdida de registros; los relojes no están verificados.

Conclusión estructurada

Entre el acceso reportado y la alerta hay 61 minutos; no se conoce la trazabilidad completa de atención.

Referencia: A04-INTERVALO

Fuentes vinculadas

- Sesión remota sin verificación adicional (EVT-02) · versión auditoria_oficina_v2.1
- Alerta crítica de seguridad (EVT-08) · versión auditoria_oficina_v2.1
- Alerta crítica de seguridad (E-07) · versión auditoria_oficina_v2.1

Comprobaciones

- **Pregunta:** El sistema calcula 61 minutos entre 02:17 y 03:18. ¿Qué significa ese intervalo?

  Respuesta elegida: Es el intervalo entre dos registros preliminares.

  Referencias: C04-INTERVALO · INTERVALO_ENTRE_REGISTROS

  Fuentes: Sesión remota sin verificación adicional (EVT-02) · versión auditoria_oficina_v2.1; Alerta crítica de seguridad (EVT-08) · versión auditoria_oficina_v2.1; Alerta crítica de seguridad (E-07) · versión auditoria_oficina_v2.1

Limitaciones

- No se conoce el inicio real del ataque. (L04-INICIO)
- Sin cierre documentado no equivale a ausencia de acción. (L04-ATENCION)
- No hay objetivo aplicable de detección o atención aportado. (L04-OBJETIVO)

Solicitudes y pendientes

- Solicitar asignación, primera acción, escalamiento y cierre. (S04-ATENCION)

Acciones propuestas relacionadas

- Acción 1: Organizar la respuesta y registrar decisiones. Propuesta; no ejecutada.

- Acción 2: Obtener el registro original de atención de la alerta crítica. Propuesta; no ejecutada.
- Acción 9: Probar seguimiento completo con una alerta controlada. Propuesta; no ejecutada.

Anotación personal · sin evaluación automática

Sin anotación personal.

Recomendación y prueba de cierre · sin evaluación automática

Acción: No registrada
Responsable: No asignado
Plazo propuesto: No registrado
Verificación: No registrada

Respaldo y recuperación Documentado

Referencia de revisión: AU-05

RTO es el tiempo objetivo para restablecer el servicio. RPO es la pérdida de datos tolerable expresada en tiempo. BIA es el análisis del impacto de una interrupción en el negocio.

Los 315 minutos hasta consulta y los 355 hasta escritura describen el retorno reportado. No demuestran integridad ni cumplimiento de los objetivos de recuperación. Faltan objetivos aprobados, el respaldo usado y pruebas de datos recuperados. El registro de julio del laboratorio es ficticio; no se ejecutó una restauración real.

Conclusión estructurada

Hay respaldos programados y recuperación por etapas reportada; no se demuestra restauración validada ni cumplimiento de objetivos de recuperación del negocio.

Referencia: A05-NO_VERIFICADA

Fuentes vinculadas

- Respaldos (E-08) · versión auditoria_oficina_v2.1
- Caída del sistema comercial (EVT-09) · versión auditoria_oficina_v2.1
- Sistema comercial disponible para consulta (EVT-11) · versión auditoria_oficina_v2.1
- Escritura restablecida (EVT-12) · versión auditoria_oficina_v2.1
- Declaración de Continuidad (DECL-07) · versión auditoria_oficina_v2.1

Comprobaciones

- **Pregunta:** Los intervalos son 315 minutos hasta solo consulta y 355 hasta escritura. ¿Esto demuestra una restauración validada dentro de los objetivos del negocio?

  Respuesta elegida: No; faltan prueba de restauración y objetivos aplicables.

  Referencias: C05-RECUPERACION · FALTAN_PRUEBA_Y_OBJETIVOS

  Fuentes: Respaldos (E-08) · versión auditoria_oficina_v2.1; Caída del sistema comercial (EVT-09) · versión auditoria_oficina_v2.1; Sistema comercial disponible para consulta (EVT-11) · versión auditoria_oficina_v2.1; Escritura restablecida (EVT-12) · versión auditoria_oficina_v2.1; Declaración de Continuidad (DECL-07) · versión auditoria_oficina_v2.1

Limitaciones

- La programación no acredita una ejecución exitosa. (L05-EJECUCION)
- Faltan respaldo usado, punto recuperable e integridad verificada. (L05-RESTAURACION)

- Faltan objetivos aprobados de tiempo de recuperación (RTO) y de pérdida temporal de datos tolerable (RPO). (L05-OBJETIVOS)

Solicitudes y pendientes

- Solicitar informe de restauración, respaldo utilizado, validación y comparación de órdenes y facturas. (S05-PRUEBA)

Acciones propuestas relacionadas

- Acción 7: Restaurar un respaldo validado en un entorno separado. Propuesta; no ejecutada.
- Acción 8: Comparar órdenes afectadas con historial, facturación y respaldo. Propuesta; no ejecutada.
- Acción 11: Decidir retorno progresivo del servicio con aceptación del negocio. Propuesta; no ejecutada.

Anotación personal · sin evaluación automática

Sin anotación personal.

Recomendación y prueba de cierre · sin evaluación automática

Acción: No registrada
Responsable: No asignado
Plazo propuesto: No registrado
Verificación: No registrada

Protección de registros y horarios Documentado

Referencia de revisión: AU-06

Metadatos son datos sobre un archivo, como su ruta y procedencia. SHA-256 es una huella calculada de sus bytes. Compararla con una referencia previamente registrada permite detectar cambios; no demuestra verdad ni completitud. Hay que conservar el origen de esa referencia.

Aquí se consultan metadatos del resumen, sin leer archivos ni calcular huellas digitales ni comprobar permisos efectivos. Los permisos se probaron solo en el laboratorio ficticio. La protección de los registros y el seguimiento de la alerta siguen pendientes de comprobar; faltan originales y relojes verificados. Las huellas de los anexos no autentican el incidente.

Conclusión estructurada

La procedencia académica está identificada; custodia de extracciones y sincronización de fuentes no están acreditadas.

Referencia: A06-LIMITACION

Fuentes vinculadas

- Inventario de archivos y custodia (META-CUSTODIA) · versión auditoria_oficina_v2.1
- Relojes y horas originales (META-TIEMPO) · versión auditoria_oficina_v2.1

Comprobaciones

- **Pregunta:** ¿Puede tratarse este resumen como una extracción con custodia acreditada?

  Respuesta elegida: No; faltan originales, método de obtención, responsable de custodia y huellas digitales.

  Referencias: C06-CUSTODIA · CUSTODIA_NO_ACREDITADA

  Fuentes: Inventario de archivos y custodia (META-CUSTODIA) · versión auditoria_oficina_v2.1

- **Pregunta:** ¿Qué muestra la comparación entre hora reportada, original, desfase y verificación?

  Respuesta elegida: La sincronización de las fuentes no está verificada.

  Referencias: C06-RELOJ · SINCRONIZACION_NO_VERIFICADA

  Fuentes: Relojes y horas originales (META-TIEMPO) · versión auditoria_oficina_v2.1

Limitaciones

- Un resumen no equivale a una extracción. (L06-RESUMEN)

- Comparar la huella digital SHA-256 de un archivo con una referencia previamente registrada permite detectar cambios; no demuestra verdad ni completitud. Debe conservarse el origen de la referencia. (L06-HASH)
- Un desfase desconocido no es cero verificado. (L06-TIEMPO)

Solicitudes y pendientes

- Solicitar originales preservados, método de obtención, responsable de custodia y huellas digitales. (S06-EXTRACCIONES)

Acciones propuestas relacionadas

- Acción 3: Preservar registros, memoria e imágenes de equipos disponibles. Propuesta; no ejecutada.
- Acción 5: Obtener permisos, conservación y configuración de relojes. Propuesta; no ejecutada.
- Acción 10: Probar conservación de registros y rechazo de modificaciones. Propuesta; no ejecutada.

Anotación personal · sin evaluación automática

Sin anotación personal.

Recomendación y prueba de cierre · sin evaluación automática

Acción: No registrada
Responsable: No asignado
Plazo propuesto: No registrado
Verificación: No registrada

Once acciones propuestas para las primeras 72 horas

Las once acciones siguen siendo propuestas. Los plazos máximos se cuentan desde la futura activación del plan por la administración. La administración decide y ejecuta; el auditor recomienda y evalúa. Preservar y contener se coordinan: una medida urgente ante daño activo no espera una recopilación perfecta; se documenta qué se conserva o pierde. Recuperar y volver a escribir dependen de respaldo limpio, validación, comparación de órdenes y aceptación del negocio. Faltan costos y evaluación del riesgo restante; estas 72 horas no sustituyen el plan completo de 90 días.

1. **Organizar la respuesta y registrar decisiones**

   Administración y Seguridad · máximo propuesto: 4 horas desde la activación.

   Prueba de cierre: Decisiones y asignaciones con responsable y hora, contrastadas con comunicaciones.

2. **Obtener el registro original de atención de la alerta crítica**

   Seguridad y monitoreo · máximo propuesto: 12 horas desde la activación.

   Prueba de cierre: Registro original contrastado con acciones, escalamiento y aceptación del cierre.

3. **Preservar registros, memoria e imágenes de equipos disponibles**

   Equipo forense y custodio designado por la empresa · máximo propuesto: 6 horas desde la activación.

   Prueba de cierre: Copias con origen, fecha, huella y acceso registrado; pérdidas justificadas.

4. **Decidir aislamiento selectivo y revocar accesos en riesgo**

   Seguridad, identidades e Infraestructura, bajo la administración · máximo propuesto: 6 horas desde la activación.

   Prueba de cierre: Cambio autorizado y prueba de rechazo del acceso revocado; excepciones registradas.

5. **Obtener permisos, conservación y configuración de relojes**

   Infraestructura, base de datos y Seguridad · máximo propuesto: 24 horas desde la activación.

   Prueba de cierre: Configuración y originales; cobertura y desfases comprobados o desconocidos explícitos.

6. **Investigar contenido y autorización de la transferencia externa**

   Seguridad, nube y proveedor autorizado · máximo propuesto: 24 horas desde la activación.

   Prueba de cierre: Originales que conecten sesión, proceso y objetos; destino y autorización comprobados.

7. **Restaurar un respaldo validado en un entorno separado**

   Administración, Continuidad y base de datos · máximo propuesto: 48 horas desde la activación.

   Prueba de cierre: Prueba real autorizada de restauración, integridad y revisión de señales de compromiso.

8. **Comparar órdenes afectadas con historial, facturación y respaldo**

   Sistema comercial, Finanzas y base de datos · máximo propuesto: 72 horas desde la activación.

   Prueba de cierre: Todas las órdenes identificadas comparadas, con fuentes y diferencias justificadas o excepción expresa.

9. **Probar seguimiento completo con una alerta controlada**

   Seguridad y monitoreo · máximo propuesto: 72 horas desde la activación.

   Prueba de cierre: Alerta de prueba con asignación, acciones, escalamiento y cierre; objetivo aprobado antes del ensayo.

0. **Probar conservación de registros y rechazo de modificaciones**

   Infraestructura y Seguridad · máximo propuesto: 72 horas desde la activación.

   Prueba de cierre: Evento controlado recibido completo y cambios no autorizados rechazados, sin alterar registros del incidente.

1. **Decidir retorno progresivo del servicio con aceptación del negocio**

   Administración, negocio y Continuidad · máximo propuesto: 72 horas desde la activación.

   Prueba de cierre: Pruebas de seguridad, integridad y comparación de órdenes antes de habilitar escritura; excepciones aceptadas con responsable.

Límites generales del expediente de referencia

- Persona que usó ext_ops_04 y relación con la solicitud del día 12.
- Contenido transferido y conexión probada entre la lectura SQL y el flujo externo.
- Identidad y sesión que explican los cambios de órdenes; conciliación e integridad final.
- Relación causal del despliegue con el incidente.
- Hora de primera acción ante la alerta y respuesta completa ejecutada.
- Horas originales, fiabilidad y desfases de cada fuente.
- Respaldo exacto usado, punto recuperable y cumplimiento de objetivos de negocio.
- Cadena de custodia completa de extracciones no aportadas.
- Escala y calibración del puntaje de IA.

Referencias de trazabilidad: contenido auditoria_oficina_v2.1 · reglas auditoria_reglas_v2.1.
Generado localmente, sin conexión a SQL Server ni servicios remotos. La hora de exportación no es una hora del incidente.

